

# Security+ 2.2 · Impersonation

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.2 — Impersonation (5:52) · [vídeo original](#)  
[↗](#) · [YouTube](#) [↗](#)

Roubo de identidade na conversa: BEC (Business Email Compromise — 'falo pelo CEO'); tailgating (entrar na porta atrás da pessoa); shoulder surfing (olhar sobre o ombro); dumpster diving (papel na lixeira); brand impersonation (falso suporte).

## Highlights que a prova cobra

- BEC: o email SE PASSA pelo executivo (vítima interna)
- Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC
- Tailgating: entra na porta atrás de quem tem acesso

## Dicas de prova

- 'sender claims to be an executive' = BEC
- 'follows an authorized person through a door' = tailgating/piggybacking

**Cenário clássico:** Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgente' = BEC — não whaling (whaling MIRA o CEO; BEC SE PASSA por ele).

## Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A)** Vishing
- B)** Pretexting
- C)** Baiting
- D)** Tailgating

3. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A)** Escassez
- B)** Autoridade + urgência
- C)** Prova social
- D)** Reciprocidade

4. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Clonagem de credenciais
- D)** Dumpster diving

5. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'BEC: o email SE PASSA pelo executivo (vítima interna)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: BEC: o email SE PASSA pelo executivo (vítima interna)...

**6.** Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**7.** Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Tailgating: entra na porta atrás de quem tem acesso'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Tailgating: entra na porta atrás de quem tem acesso...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8.** Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'sender claims to be an executive' = BEC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'sender claims to be an executive' = BEC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9.** Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'follows an authorized person through a door' = tailgating/piggybacking'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'follows an authorized person through a door' = tailgating/piggybacking...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10.** Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgente' = BEC — não whaling (whaling MIRA o CEO; BEC SE PASSA por ele)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgen...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

## GABARITO COMENTADO

- 1) A — BEC / CEO fraud (fraude do CEO).** BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima)
- 2) A — Vishing.** Vishing = phishing por VOZ/telefone (a 'ligação' é a chave). O golpista finge ser o suporte pra extrair a senha. (Pretexting é a técnica do cenário inventado, muitas vezes usada JUNTO com o vishing.)
- 3) B — Autoridade + urgência.** Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro.
- 4) C — Clonagem de credenciais.** Clonagem de credenciais RFIDs permite criar cópias não autorizadas de crachás/cartões de acesso, permitindo entrada física não autorizada em instalações.
- 5) D — Implementar a solução correspondente: BEC: o email SE PASSA pelo executivo (víti.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): BEC: o email SE PASSA pelo executivo (vítima interna). As demais alternativas configuram violações graves de conformidade
- 6) C — Implementar a solução correspondente: Whaling: o email MIRA o executivo (spear d.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC. As demais alternativas configuram violações grave
- 7) A — Implementar a solução correspondente: Tailgating: entra na porta atrás de quem t.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): Tailgating: entra na porta atrás de quem tem acesso. As demais alternativas configuram violações graves de conformidade
- 8) C — Implementar a solução correspondente: 'sender claims to be an executive' = BEC...** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): 'sender claims to be an executive' = BEC. As demais alternativas configuram violações graves de conformidade ou falhas
- 9) B — Implementar a solução correspondente: 'follows an authorized person through a do.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): 'follows an authorized person through a door' = tailgating/piggybacking. As demais alternativas configuram violações gr
- 10) B — Implementar a solução correspondente: Cenário: 'atacante manda email dizendo ser.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgente' = BEC — não whaling (whaling MIRA o CEO;

